

DATA PROCESSING ADDENDUM

This Data Processing Addendum (“**DPA**”) is entered into as of [●] (“**Effective Date**”) and forms an integral part of the [Principal Agreement] (“**Principal Agreement**”) executed between: [Data Fiduciary Name], having its principal place of business at [●] (“**Data Fiduciary**”), and [Data Processor Name], having its principal place of business at [●] (“**Data Processor**”).

The Data Fiduciary and Data Processor are collectively referred to as the “**Parties**” and individually as a “**Party**”.

WHEREAS:

- A. The Parties have entered into the Principal Agreement dated [●], under which the Data Processor provides certain services to the Data Fiduciary.
- B. In the course of performing such services, the Data Processor may Process certain categories of Personal Data on behalf of the Data Fiduciary as set out in **Annexure A**. This Addendum records the Parties’ respective rights and obligations concerning such Processing in accordance with applicable Data Protection Laws (as defined below).
- C. This Addendum supplements and forms an integral part of the Principal Agreement and sets out the terms governing the Processing of Personal Data by the Data Processor on behalf of the Data Fiduciary.

NOW, THEREFORE, in consideration of the mutual undertakings contained herein and in the Principal Agreement, the Parties agree as follows:

1. PURPOSE, SCOPE, AND PRECEDENCE

- 1.1 This DPA is executed pursuant to the Digital Personal Data Protection Act, 2023 (“**Act**”), which requires that any engagement of a Data Processor by a Data Fiduciary shall be under a valid contract.
- 1.2 This DPA governs the Processing of Personal Data under the Principal Agreement in accordance with the Act and the Digital Personal Data Protection Rules, 2025 (“**Rules**”).
- 1.3 In the event of any conflict between this DPA and the Principal Agreement, this DPA shall prevail with respect to Processing of Personal Data.
- 1.4 Nothing in this DPA assigns to the Data Processor any role or obligation reserved exclusively for the Data Fiduciary under the Act.

***Guidance Note:** This clause explains why the Addendum exists. Section 8(2) of the DPDP Act requires that a Data Fiduciary may only engage a Data Processor under a valid contract. The recital and Clause 1 clarify that this DPA supplements the Principal Agreement to satisfy that statutory requirement.*

2. DEFINITIONS

- 2.1 Capitalized terms used but not defined herein shall have the meaning assigned under the Act or Rules.
- 2.2 For purposes of this DPA:
 - “**Data Protection Laws**” means the Act, Rules, and any applicable privacy or data protection laws.
 - “**Restricted Transfer**” means any transfer of Personal Data outside India that is subject to restrictions under the Act or applicable Government notification.
 - “**Personal Data**” means any personal data Processed under this DPA.
 - “**Processing**” means any operation performed on Personal Data.
 - “**Data Principal**” means the individual to whom the Personal Data relates.
 - “**Security Safeguards**” means the measures mandated under the Act and Rules.

- “**Sub-processor**” means any third party engaged by the Data Processor to assist with Processing.

3. ROLES AND RESPONSIBILITIES

- 3.1 The Data Fiduciary determines the purpose and means of Processing Personal Data.
- 3.2 The Data Processor acts solely on behalf of the Data Fiduciary and shall Process Personal Data only in accordance with this DPA and documented instructions.
- 3.3 The Data Processor shall not Process Personal Data for its own purposes, including profiling, analytics, resale, marketing, or product improvement, unless expressly authorised in writing by the Data Fiduciary.
- 3.4 Nothing in this DPA constitutes joint controllership, joint fiduciary status, or the assignment of independent fiduciary obligations to the Data Processor.

Guidance Note: Under Section 2(i) (Data Fiduciary definition) and Section 2(k) (Data Processor definition) of the Act, only the Data Fiduciary determines purpose and means of processing. The Processor cannot act independently. This aligns with Section 8(2) of the Act which requires a contract that explicitly controls the processor’s role. The “no independent purpose” clause also prevents unauthorised profiling, analytics, or secondary use.

4. PROCESSING ON DOCUMENTED INSTRUCTIONS

- 4.1 The Data Processor shall Process Personal Data only in accordance with:
 - (a) the documented instructions of the Data Fiduciary;
 - (b) the purposes specified in Annexure A; and
 - (c) applicable law.
- 4.2 The Data Processor shall immediately notify the Data Fiduciary if an instruction is unlawful or incapable of being performed.
- 4.3 The Data Processor shall not make unilateral decisions regarding retention, disclosure, modification, or any other Processing operations concerning the Personal Data.
- 4.4 If the Data Processor believes that any instruction from the Data Fiduciary infringes Data Protection Laws, the Data Processor shall notify the Data Fiduciary without undue delay and suspend execution of the instruction until the Parties agree on revised, lawful instructions.

Guidance Note: This clause reflects **Section 8(2)** of the DPDP Act, which requires that a Data Processor may process Personal Data only under a valid contract and only “on behalf of” the Data Fiduciary. If the Processor acts outside instructions, it risks being treated as a Data Fiduciary for that processing. The escalation step ensures instructions do not conflict with Data Protection Laws.

5. CONFIDENTIALITY

- 5.1 The Data Processor shall ensure that all personnel with access to Personal Data are bound by written confidentiality obligations.
- 5.2 Access to Personal Data shall be limited to personnel who require such access for the performance of obligations under the Principal Agreement.
- 5.3 The Data Processor shall maintain appropriate internal confidentiality, security, and data-handling policies, including periodic training.
- 5.4 The Data Processor shall maintain written records evidencing that all authorised personnel have executed confidentiality and data protection undertakings no less protective than those contained in this Addendum, and shall make such records available upon reasonable request.

Guidance Note: Confidentiality obligations arise from the general duty of reasonable security practices under **Section 8(5)** of the DPDP Act. Personnel confidentiality is not explicitly mandated in the Act, but

it is required implicitly under “reasonable security safeguards,” and also aligns with **Rule 6** which requires access controls and authorised personnel management.

6. SECURITY SAFEGUARDS

- 6.1 The Data Processor shall implement Security Safeguards appropriate to the nature of Personal Data and the risks associated with Processing. Such safeguards shall include, at a minimum:
- (a) encryption or tokenization;
 - (b) access control and authentication mechanisms;
 - (c) logging and monitoring of access events;
 - (d) retention of logs for at least **one year**;
 - (e) secure coding standards and vulnerability management;
 - (f) incident detection and response capabilities;
 - (g) secure disposal processes;
 - (h) network security and segmentation.
- 6.2 The Data Processor shall periodically review and update its Security Safeguards to maintain alignment with industry standards and evolving threats.
- 6.3 The Data Processor shall maintain security controls materially equivalent to industry standards such as **ISO/IEC 27001**, **SOC 2 Type II**, or any successor standards applicable to the nature of Processing.
- 6.4 Encryption shall meet or exceed the following minimum specifications:
- (a) **AES-256** or equivalent for encryption at rest;
 - (b) **TLS 1.2+** for encryption in transit.
- 6.5 The Data Processor shall perform annual penetration testing, continuous or monthly vulnerability scanning, and shall remediate identified high-risk vulnerabilities within [●] days.
- 6.6** The Security Safeguards set out in **Annexure B** form an integral part of this Addendum and the Data Processor shall implement and maintain them at all times.

***Guidance Note:** This clause is based on **Section 8(5)** of the DPDP Act, which requires a Data Fiduciary to implement reasonable security safeguards to prevent personal data breaches including in respect of processing carried out **on its behalf by a Data Processor**. **Rule 6(1)(a)–(g)** further prescribes specific minimum safeguards such as encryption, access control, logging for one year, incident detection, and protection against unauthorised access. Annexure B sets out the detailed minimum-security controls aligned with these requirements and incorporating it by reference makes those measures contractually binding and enforceable.*

7. BUSINESS CONTINUITY AND DISASTER RECOVERY

- 7.1 The Data Processor shall maintain comprehensive Business Continuity (“**BC**”) and Disaster Recovery (“**DR**”) plans.
- 7.2 BC/DR plans shall include:
- (a) backup and restoration capabilities;
 - (b) redundancy and failover procedures;
 - (c) defined RTO and RPO;
 - (d) continuity procedures for critical operations.
- 7.3 BC/DR plans shall be tested periodically and summaries made available upon request.
- 7.4 Any event materially affecting service availability shall be reported to the Data Fiduciary without undue delay.
- 7.5 The Data Processor shall maintain clearly defined RTO (Recovery Time Objective) and RPO (Recovery Point Objective) values of [●] hours each, unless otherwise agreed in writing.

- 7.6 Business continuity and disaster recovery plans shall be tested at least annually, and a summary of the test results shall be provided to the Data Fiduciary within 14 days of completion.

***Guidance Note:** DPDP Act and Rules do not explicitly reference business continuity or disaster recovery, but these obligations are part of “reasonable security safeguards” under **Section 8(5)**. If a system outage compromises confidentiality, integrity, or availability of data, it may constitute a “personal data breach.” Hence BC/DR may be considered under Rule 6(a) and 6(b) (risk mitigation and system resilience).*

8. PERSONAL DATA BREACH MANAGEMENT

- 8.1 The Data Processor shall notify the Data Fiduciary **immediately and without undue delay**, and in any event within **24 hours**, upon becoming aware of a Personal Data Breach.
- 8.2 The notification shall include:
- (a) nature and cause of the breach;
 - (b) categories and volume of affected Personal Data;
 - (c) likely consequences;
 - (d) steps taken to mitigate harm;
 - (e) information necessary for compliance with the Data Protection Laws including **Section 8(6)** of the Act and **Rule 7**.
- 8.3 The Data Processor shall cooperate fully in containment, investigation, and regulatory reporting efforts.
- 8.4 A detailed incident report shall be provided within 72 hours of initial notification, including root cause, remedial actions, containment measures, and potential impact on Data Principals.

***Guidance Note:** This clause is required under:*

- **Section 8(6)** — Data Fiduciary must notify the Data Protection Board & affected individuals in the event of a personal data breach.
- **Rule 7** — Specifies what must be included in the notification. Processors must inform Fiduciaries “without undue delay,” and 24-hour SLA ensures the fiduciary can meet its legal deadline.

9. ASSISTANCE WITH DATA PRINCIPAL RIGHTS

- 9.1 The Data Processor shall assist the Data Fiduciary in responding to Data Principal requests, including: (a) access; (b) correction; (c) erasure; (d) withdrawal of consent; (e) grievance redressal.
- 9.2 The Data Processor shall not respond directly to any Data Principal without written instruction.
- 9.3 The Data Processor shall acknowledge any request from the Data Fiduciary to assist with a Data Principal right within 48 hours, and shall provide reasonable assistance to enable the Data Fiduciary to respond within 7 business days, or earlier if required by Data Protection Laws.

***Guidance Note:** Data Processors must assist the Data Fiduciary in fulfilling Data Principal rights because the Fiduciary is ultimately responsible for responding to such requests under: **Section 11 (Access)**, **Section 12 (Correction/Erasure)**, **Section 13 (Grievance Redressal)**. Processors cannot respond directly (unless authorised) because they are not the legal point of contact for Data Principals.*

10. SUB-PROCESSORS

- 10.1 The Data Processor shall not engage any Sub-processor without prior written approval of the Data Fiduciary.

- 10.2 Sub-processors must be bound by obligations no less protective than those contained in this DPA.
- 10.3 The Data Processor shall remain fully liable for Sub-processors' acts and omissions.
- 10.4 The Data Processor shall maintain and update a list of approved Sub-processors.
- 10.5 The Data Processor shall provide the Data Fiduciary with 30 days' prior written notice of any intended addition or replacement of a Sub-processor. The Data Fiduciary may object on reasonable data protection grounds within 10 business days.
- 10.6 The Data Processor shall ensure that written contracts with all Sub-processors impose obligations no less protective than those set out in this Addendum, including confidentiality, security, audit, and return/erasure obligations.
- 10.7 The list of approved Sub-processors is set out in Annexure C, which forms an integral part of this Addendum. The Data Processor shall keep Annexure C updated in accordance with Clause 10.5.

Guidance Note: The DPDP Act and Rules do not expressly refer to "Sub-processors." However, **Section 8(2)** requires that processing carried out on behalf of a Data Fiduciary occur under a valid contract, and **Rule 6(1)** requires this contract to include appropriate provisions to ensure reasonable security safeguards, including for processing undertaken "on its behalf." In practice, this necessitates contractual oversight of all downstream processors engaged by the primary Data Processor. The notice-and-objection mechanism is a global best practice (not a DPDP requirement) that enhances transparency and control over onward processing. **Annexure C** provides the list of approved Sub-processors and makes disclosure and approval contractually binding.

11. RETENTION, RETURN, AND ERASURE

- 11.1 The Data Processor shall retain Personal Data only for the period instructed by the Data Fiduciary or required under law.
- 11.2 Within 30 days of cessation of the Services or expiry of the Principal Agreement, the Data Processor shall, at the Data Fiduciary's election:
 - (a) return all Personal Data in a structured, commonly used format; or
 - (b) permanently erase all Personal Data and certify completion of erasure within 14 days.The Data Processor may retain Personal Data only to the extent required by law and shall segregate and restrict access to such retained data.
- 11.3 Retention of system logs for at least one year shall comply with Data Protection Laws including Rule 6.

Guidance Note: This clause reflects, **Section 8(7)(b)** - Data Fiduciary must cause its Data Processor to erase data once purpose is fulfilled or consent is withdrawn. The certificate of destruction is a best practice to demonstrate compliance.

12. AUDIT AND ASSESSMENT RIGHTS

- 12.1 The Data Fiduciary or its auditors may conduct audits or assessments upon reasonable notice.
- 12.2 The Data Processor shall provide access to relevant personnel, systems, processes, and documentation.
- 12.3 Where the Data Fiduciary is a **Significant Data Fiduciary**, the Data Processor shall support all required compliance activities, including DPIAs.
- 12.4 The Data Fiduciary may conduct one remote audit per year and one onsite audit every two years, except where a Personal Data Breach or material incident warrants additional audits.
- 12.5 All audit reports, summaries, and findings shall be treated as Confidential Information.

Guidance Note: The DPDP Act does not expressly mandate audit rights over Data Processors. However, **Section 8(1)** makes the Data Fiduciary responsible for compliance even where processing is carried out on its behalf by a Data Processor, and **Section 8(2)** requires such processing to be governed by a valid contract. Audit and assessment rights are therefore a contractual mechanism that enable the Data Fiduciary to verify the Data Processor's security and compliance posture. Further, **Section 8(5)** requires "reasonable security safeguards," and audits help demonstrate that

*these safeguards are implemented. Where the Data Fiduciary is a Significant Data Fiduciary, **Section 10** requires periodic audits, risk assessments, and DPIAs; Data Processors must cooperate in these activities, and this clause enables such cooperation.*

13. CROSS-BORDER TRANSFERS

- 13.1 The Data Processor shall not transfer Personal Data outside India except on documented instructions from the Data Fiduciary and in compliance with Data Protection Laws and any applicable Government notification issued restricting such transfers.
- 13.2 For any permitted transfer, the Data Processor shall implement appropriate contractual, organisational, and technical safeguards to ensure a level of protection equivalent to that required under this Addendum.
- 13.3 The Data Processor shall promptly notify the Data Fiduciary if it becomes aware that a destination jurisdiction is designated as a restricted or prohibited location for transfers under applicable law.

***Guidance Note:** This clause reflects **Section 16** of the DPDP Act, which allows the Central Government to restrict or prohibit transfers of personal data to specified countries or territories. **Rule 15** sets out the procedure for issuing such notifications. Accordingly, a Processor may transfer data outside India only on the Data Fiduciary's instructions and only where no Government restriction applies. The requirement to apply contractual, organisational, and technical safeguards aligns with global best practices and ensures the DPA remains usable for international processing arrangements.*

14. LIABILITY AND INDEMNITY

- 14.1 The Data Processor shall indemnify the Data Fiduciary for losses, penalties, claims, and liabilities arising from: (a) breach of this DPA; (b) inadequate Security Safeguards; (c) unauthorized access, disclosure, or Processing; (d) failure to return or delete Personal Data.
- 14.2.1 The Data Processor's liability for confidentiality breaches, security incidents, violations of applicable laws, or breach of its obligations under this DPA shall be unlimited.
- 14.2.2 The Data Processor shall maintain cyber liability insurance with minimum coverage of **INR [●] crore / USD [●]** and shall provide evidence of such coverage upon request.

***Guidance Note:** The DPDP Act places primary responsibility for compliance on the Data Fiduciary under **Section 8(1)**, even where processing is carried out by a Data Processor on its behalf. Penalties under the Act apply to the party that is legally obligated to comply typically the Data Fiduciary which makes contractual indemnities essential to shift operational risk back to the Processor. Unlimited liability for confidentiality, security, and data protection breaches reflects global data protection contracting standards and ensures that the Processor remains fully accountable for failures within its control.*

15. MISCELLANEOUS

- 15.1 This Addendum is entered into for the duration set out in the Principal Agreement and this Addendum may not be terminated in the interim.
- 15.2 Each Party hereto hereby represents that it has the legal and corporate right and full power and authority to enter into and deliver this Addendum, to perform its obligations hereunder and to consummate its actions and obligations contemplated hereby.
- 15.3 The terms of this Addendum shall on and from the Effective Date be deemed to have been incorporated and be an integral part of the Principal Agreement.

- 15.4 The provisions of the Principal Agreement relating to **Governing Law, Jurisdiction, and Limitation of Liability** shall apply **mutatis mutandis** to this Addendum and are incorporated herein by reference.
- 15.5 The obligations relating to confidentiality, audit, security, indemnity, and return or erasure of Personal Data shall survive termination of this Addendum for a period of five (5) years, or such longer period as required under applicable law.
- 15.6 The provisions of this Addendum shall be binding upon and inure to the benefit of the Parties hereto and their respective successors and permitted assigns and affiliate.
- 15.7 The execution and delivery of this Addendum by delivery of a facsimile or electronically recorded copy bearing a copy of the signature of a party shall constitute a valid and binding execution and delivery of this Addendum by such party. Such copies shall constitute enforceable original documents.

FOR DATA FIDUCIARY Signature: _____ Name: _____ Title: _____ Date: _____	FOR DATA PROCESSOR Signature: _____ Name: _____ Title: _____ Date: _____
---	---

ANNEXURE A — DETAILS OF PROCESSING

Category	Details
Nature & Purpose of Processing Provision of Services under the Principal Agreement, including authentication, analytics, hosting, support, communication, and data management.	[•]
Categories of Personal Data	[•]
Categories of Data Principals	[•]
Duration of Processing	[•]
Processing Operations Collection, recording, organisation, storage, retrieval, transmission, analysis, backup, deletion, and disposal.	[•]
Storage Location	[•]
Access Roles System administrators, security engineers, support personnel, and other authorised roles operating under least-privilege and role-based access.	[•]

ANNEXURE B — SECURITY MEASURES

The Data Processor shall implement, at a minimum:

- Encryption at rest & in transit
- Pseudonymization or masking
- Network segmentation
- Incident detection & response systems
- Access control & authentication mechanisms
- Regular vulnerability scanning & penetration testing
- Backup & restoration procedures
- Physical security controls
- Vendor risk management processes
- One-year log retention (minimum)

ANNEXURE C — APPROVED SUB-PROCESSORS

Sub-processor name(s)	Service	Country	Safeguards
[•]	[•]	[•]	[•]